Implement AI Security in the Generative AI Workflow

17 October 2025 - ID G00832004 - 16 min read

By Joerg Fritsch, Marissa Schmidt, and 1 more

Cybersecurity leaders responsible for GenAI development, security or operations must adapt their security practices. GenAI workflows must be secured in their six stages, consisting of data acquisition, models, generation, deployment, compliance monitoring and feedback loops.

Overview

Key Findings

- GenAI workflows differ from the workflows cybersecurity leaders have had to secure in the past. They follow a unique process that mitigates distinctive security risks at different stages.
- There is no single, centralized management console for GenAI security yet. Each stage consists of dedicated technology stacks and tool chains to implement required controls.
- Many organizations face “data security debt,” that is, data security concerns that have gone unaddressed but are frequently revealed as key areas of concern in implementing GenAI.
- Maintaining consistent and context-aware security and governance controls becomes increasingly challenging, as raw data, models and feedback data proliferate.
- Continuous feedback is critical: Iterative feedback loops aren’t just nice to have — they’re necessary to detect drift, remediate vulnerabilities and ensure outputs remain helpful, honest, and harmless (3H).

Recommendations

Cybersecurity leaders must:

- Incorporate stage-specific safeguards throughout the GenAI workflow, such as data classification and cataloging, model red teaming, guardrails for multistep architectures or data leakage prevention.
- Consolidate governance by investing in or integrating an AI security platform that spans many environments — all is currently unachievable.
- Mandate security and quality of training data and quality of metadata for accurate context by maturing data provenance, and budgeting for tools that provide visibility and control (such as DSPM, entitlement management and bias detection).
- Automate model security by integrating vulnerability scanning, model drift detection, AI red teaming and adversarial-robustness testing into the CI/CD pipeline.
- Institute constitutional AI and human-in-the-loop processes by focusing on TRiSM and 3H principles (helpful, honest, harmless) via a constitutional AI workflow.

Introduction

The GenAI workflow, as shown in Figure 1, is a continuous process that prioritizes an agile approach to AI — much like DevOps and DevSecOps. It emphasizes ongoing learning, iterative improvement, feedback loops, and model retraining while maintaining a human in the loop. The workflow comprises six stages, each requiring the integration of security controls as shown in Table 1.

AI Security for the Generative AI Workflow

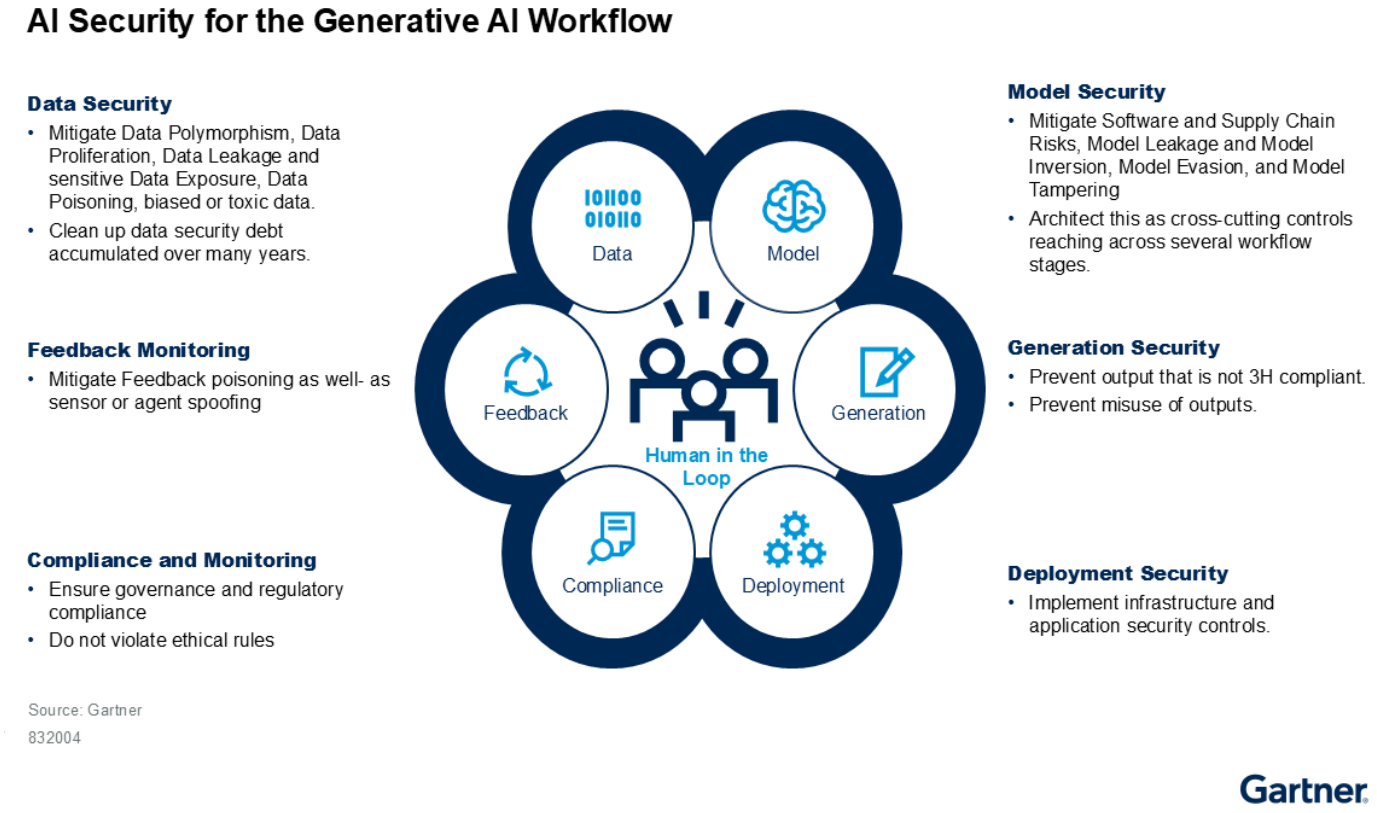
Workflow stage	Controls
Data (acquisition) stage	Data ingested by GenAI must be safe, protected, and free from security risks.

Model stage	The underlying AI model must be protected from attacks and vulnerability exploits.
Generation stage	Outputs must be helpful, harmless and honest (3H) and not be misused.
Deployment stage	Infrastructure and application security controls must be implemented.
Compliance and monitoring	Implement components (such as disclosure programming, security monitoring tools, and guardrails) necessary for regulatory requirements and design for compliance.

Source: Gartner (October 2025)

Maintaining a human in the loop is necessary for GenAI workflows (see Figure 1). Although GenAI tools can increasingly automate and accelerate many aspects of development, security, and operations, human oversight remains needed for validating outputs, mitigatir risks, and adapting to evolving compliance requirements. Cybersecurity leaders must embed human judgment into GenAI-powered workflows and DevSecOps activities to achieve a balanced approach that leverages AI efficiency while safeguarding the integrity and security of software delivery processes and the GenAI tools themselves.

Figure 1: AI Security for the Generative AI Workflow



Cross-cutting security concerns, that is, security concerns spanning several stages of the GenAI workflow, are discussed at the stages that have the primary mitigation. Examples are model evasion, model theft, and extraction. Cross-cutting controls spanning multiple stages, such as guardrails, implement several of the controls mentioned throughout. Guardrails generally include selected controls for generation security, deployment security, and feedback.

Analysis

Securing Data Acquisition

Data acquisition is the foundation for ingesting training data in batch and in real time, such as streaming data from IoT sensors, events on message queues, and other line-of-business systems. This includes converting raw data into tokens and vector embeddings and addressing data security debt. This encompasses data security concerns that have gone unaddressed but are frequently revealed as areas of concern in the process of implementing GenAI technologies, such as data classification, sensitivity labels, and the creation and storage of metadata in data catalogs.

At this stage, cybersecurity leaders must ensure that data ingested by GenAI is safe, protected, and free from security risks. Foundational controls, such as deploying DSPM tools

designed for AI and unstructured data or maintaining a comprehensive data catalog and data flow mapping, create visibility into data and the security issues posed by GenAI. Many organizations face data security debt, which can complicate secure AI deployment, as GenAI exposes the need for activities like data classification and sensitivity labeling. Addressing this data security debt early helps reduce risks throughout the AI life cycle. Incorporate a human in the loop to ensure automated processes are reviewed regularly for accuracy, compliance, and evolving security threats. Key security challenges cybersecurity leaders should consider and recommended countermeasures include:

- **Data polymorphism:** When new or nearly exact copies have been used as training data in the past (particularly unstructured data, which is more variable) or when multiple copies of data (or various versions of documents) can be used in training datasets, it is unlikely that all copies have the same metadata and security applied to them. For example, access permissions may differ, or metadata management may label some copies untrusted, outdated, or otherwise risky. Conflicting versions of unstructured data could be used to train a model, leading to inaccurate or unsafe responses.
  - *Recommended countermeasures:*
    - Leverage data discovery and classification capabilities, such as DSPM tools, and partner with data teams to identify security-minded data experts to cross-train and work alongside security staff for data discovery, cataloging, and analysis of automated results.
    - Eliminate duplicate data and address versioning issues when selecting training data.
- **Data proliferation:** Where more data is used in model training, testing, and outputs than is needed, often including unnecessary inclusion of sensitive or restricted data. This increases the risk of data breaches from AI use and potential violations of privacy regulations.
  - *Recommended countermeasures:*
    - Leverage data minimization techniques, which limit the volume and scope of sensitive data used in GenAI to only what is necessary. Data minimization supports data privacy and security by focusing on collecting, processing, and storing only the absolute minimum amount of personal data required to achieve a specified purpose.

- **Data leakage/sensitive data exposure:** When a GenAI tool allows someone to access data for which they do not have access permissions, the data needed for training contains sensitive information or regulated information that can be exposed to unauthorized staff or through model leakage.
  - *Recommended countermeasures:*
    - Anonymize sensitive data through techniques such as data masking, generalization, pseudonymization, or choose differential privacy to prevent reidentification.
- **Data poisoning:** Where an attacker intentionally introduces corrupted or misleading data into a dataset. The malicious data is then used to manipulate the model's behavior, typically by making it perform incorrectly or act in biased ways.
  - *Recommended countermeasures:*
    - Secure ingest data, including monitoring potential supply chain threats and establishing controls to prevent data poisoning via prompt injection.
- **Biased or toxic data:** Data that can lead to biased or harmful output, for example, stereotypes, illegal content, or other content not in line with corporate policies.
  - *Recommended countermeasures:*
    - Leverage security guardrails and other tools that identify problematic responses and prevent them from being returned.
- **Data security debt:** Technical debt related to the security of data that often goes unaddressed due to lower priorities assigned to unstructured data or resulting from a lack of visibility into enterprise data.
  - *Recommended countermeasures:*
    - Analyze the data security program, focusing on the security of unstructured data and the security of new data structures.
    - Develop and maintain data catalogs, data maps and data flow diagrams.
    - Implement data classification and sensitivity labeling for unstructured data in the environment.

- Develop a plan for addressing additional data security gaps needed for the secure implementation of GenAI.

Address data security debt early on to maintain data security throughout the workflow. Focus on essential data that adds new capabilities to models while avoiding ingesting unnecessary data.

Securing Models

Data scientists and engineers work together to design the architecture of the AI model (e.g., neural networks and decision trees), select algorithms and frameworks, and prepare and preprocess training data for model development.

In this stage, the focus is on protection from attacks and vulnerabilities against the underlying AI model. An AI model is a specific type of computer file containing the learned patterns and rules developed through data analytics applied to vast amounts of data in the form of mathematical formulae and/or graphs. The GenAI model can be seen as both software with dependencies on third-party software outside the model and a compressed representation of training data, and both facets must be secured. For example, a model may need to call external third-party software with elevated rights to produce a mathematical formula or graph as output. A human in the loop provides oversight, validates outputs, and ensures that security and ethical standards are maintained consistently.

Key security challenges cybersecurity leaders should consider and recommended countermeasures include:

- **Software security and supply chain risks:** Where model risks arise from supply chain or third-party software attacks.
  - *Recommended countermeasures:*
    - Leverage software composition analysis (SCA) tools to scan model dependencies — such as Python packages — for known CVEs and operating system or library vulnerabilities of the container or system where the model runs.
    - Leverage third-party risk management tools to monitor vulnerabilities in third-party software, including monitoring the supply chain that feeds that software.

- **Model leakage and model inversion:** When the training data/model includes proprietary data, trade secrets, or regulated data, there is concern that the trained model may leak parts of this data to unauthorized users.
  - *Recommended countermeasures:*
    - Test for model leakage and vulnerabilities to adversarial attacks. Canary testing can help detect unintended data exposure.
    - Consider pretraining models with less sensitive data and fine-tune with more sensitive, domain-specific data to limit potential leakage.
    - Adversarial robustness testing — such as evaluating resistance to prompt injection and model inversion attacks — should be a standard part of the model validation process to further protect sensitive information.
- **Model evasion:** When someone creates a slightly modified input that looks normal to humans but causes AI models to make mistakes. The goal is to trick AI into doing something that it should not, such as misclassifying something dangerous as safe or allowing malicious behaviors to go undetected.
  - *Recommended countermeasures:*
    - Leverage input validation and sanitization techniques.
    - Monitor model behaviors.
    - Conduct adversarial training of models.
    - Develop, implement, and maintain rapid incident response plans.
- **Model tampering:** Where someone gains access to the trained model to manipulate it, creating unintended biases, alterations introduced by attackers, or other unauthorized changes.
  - *Recommended countermeasures:*
    - Utilize code/model signing — as with other code or executables in the software development program — to verify model integrity.
    - Conceal model weights using tools like TensorFlow Privacy (based on differential privacy) to prevent attackers from modifying the models' capabilities and extracting

the weights using API queries.

Securing Generation

Generation security focuses on model execution and output handling. A focus on generation security focuses on what happens in the black box of the GenAI tool. Generation context and safety focus on processing the input (in the form of a prompt) to generate an output response for the user. The human in the loop reviews and validates outputs, helping to identify and mitigate potential risks or unintended consequences in real time.

The generation of security activities at this stage can be broken into two categories:

- **Preventing non-3H (helpful, honest and harmless) as popularized by Anthropic, compliant content after it has been generated but before it reaches users.** A constitution in the context of AI refers to a formalized set of high-level directives or principles that govern the output and behavior of an AI system that the CISO must implement or that determines how an AI governs itself. This concept ensures that AI outputs consistently align with the 3H principles. In selected environments, an organization may have multiple constitutions tailored to different use cases or audiences, providing flexibility to address specific operational needs.

- **Preventing misuse of the outputs.**

Constitutional AI is a cross-cutting framework with the most measurable impact at the generation stage. However, it also spans the model security stage (use of helpful training data) and the feedback stage (honest self-correction).

Key security challenges cybersecurity leaders should consider and recommended countermeasures include:

- **Release of non-3H compliant outputs:** Content should be helpful, honest and harmless, and GenAI tools should be monitored for release of content that violates these three principles.

  - *Recommended Countermeasures:*

    - Mandate and deploy real-time content moderation tools, such as real-time scanners. For example, real-time enforcement of 3H through real-time self-critique and generation-time rule injection, as provided by Microsoft Guidance or Anthropic Claude model API, which has built-in constitutional checks.

    - Implement real-time scanning and dynamic blocking using tools such as OpenAI moderation API, NVIDIA NeMo Guardrails, DSPM tools, Hugging Face transformers, AWS Toxic Content Detector, Intel FakeCatcher, or, established SIEM tools.

- **Output misuse:** GenAI outputs can be used to create and disseminate disinformation.
    - *Recommended countermeasures:*
        - Provide invisible watermarks or tags to indicate the output came from GenAI. Organizations needing such controls may need to develop them in-house or use commercial products, such as Adobe ContentID or Google SynthID.
        - Utilize access logging to track who uses/used the model and for what.
        - Create a playbook for taking down content that has been misused. [1]

Inserting and detecting watermarks alone cannot mitigate AI-related threats like disinformation. It also requires playbooks for content takedown workflows.

Securing Deployment

This stage protects a GenAI system from exploitation as it is deployed into a production environment while ensuring APIs and runtime environments are properly secured against unauthorized access and vulnerabilities. Continuous monitoring and security patching maintain the integrity and availability of AI services. A human in the loop during deployment provides critical oversight while enabling rapid detection and response to emerging threats or anomalous behaviors. Combining automated security measures with human expertise and oversight enables organizations to maintain robust deployment security for AI solutions.

Key security challenges cybersecurity leaders should consider and recommended countermeasures include:

- **API hijacking:** Where an attacker leverages an AI API to engage in model or data theft. This could include using the AI's API to query the model hundreds or thousands of times to reconstruct model weights.
    - *Recommended countermeasures:*

    - Leverage tools for authentication and authorization of API calls (with MFA for admins). If possible, utilize scope-based access using the Open Policy Agent or similar tools.

- **Model denial of service attacks/cost exhaustion attacks:** Model denial of service (DoS) attacks involve attackers flooding an AI model with an overwhelming number of requests or with computationally intensive inputs designed to make the model so busy processing requests that it becomes slow, unresponsive or completely crashes. Similarly, cost exhaustion attacks are designed to increase overall cost or cause cost spikes through malicious queries. The two often go hand in hand with DoS attacks, driving up costs while threatening responsiveness.
    - *Recommended countermeasures:*
        - Deploy API gateways, rate limiters and quotas, load balancers/scalers, traffic filtering, and anomaly detection tools. Couple these with tools to detect anomalies such as increased latency, custom ML alerts, spikes in error rates, or high volume outputs.
        - Leverage runtime security controls, such as Falco, for AI deployments in containers to prevent unexpected file system writes.
- **Model theft/extraction:** Occurs when an attacker repeatedly asks questions or submits queries to analyze responses so they can create a copy or a very similar version of the model by reverse engineering the AI's internal workings without having direct access to the original code or training data.
    - *Recommended countermeasures:*
        - Use rate limitation tools, user authentication and authorization, adversarial training, and anomaly detection tools to monitor query patterns.

Monitoring Compliance

This stage addresses introducing components (such as disclosure programming, security monitoring tools and guardrails) necessary for regulatory requirements and designing for compliance. Compliance management and monitoring GenAI workflows and business applications ensure proactively meeting required compliance goals.

Examples of regulatory requirements are privacy (for example, GDPR) or AI (for example, the EU AI Act) regulations, and the company's goal to track model behavior and/or drift. At the time of writing, the U.S. has no federal AI law yet. Currently, the U.S. has several AI-related bills (laws in draft stage) and sector-specific regulations, such as the FTC, that are applied to AI but not specific to AI. Several states have passed AI-specific privacy and AI legislation, such as the Texas Data Privacy and Security Act (HB4, 88R) and the Texas Responsible Artificial Intelligence Governance Act (TRAIGA, HB 149, 89R). Regulations can require inclusion of overall disclosures about the use of AI, controls to prevent the use of AI for some categories of protected data, and other disclosures and controls in AI programming.

A human in the loop interprets complex regulatory requirements and makes informed decisions to ensure ongoing compliance in dynamic legal environments.

Key security challenges cybersecurity leaders should consider and recommended countermeasures include:

- **Governance and regulatory compliance:** AI, like other technological tools, requires compliance with various regulatory schemes.
  - *Recommended countermeasures:*
    - Implement audit logging informed by the regulatory environment.
    - Use mitigation techniques and quarantine outputs that are not 3H compliant.
    - Monitor data flows and API orchestration through, for example, LangChain, LlamaIndex or similar.
    - Keep track of data lineage to monitor who accessed or modified the data.
- **Violation of ethical rules and requirements:** GenAI continues to have ethical rules and requirements that must be monitored and enforced.
  - *Recommended countermeasures:*
    - Implement bias detection tools such as monitoring output for fairness across demographics, e.g., flagging loan denial against zip codes.
    - Monitor model drift and send alerts when model behavior deviates from the baseline, e.g., spikes in prompt refusal rates.

- Keep outcomes explainable, adding references or reasons, e.g., denied due to income.
- Don't attempt to create a comprehensive AI ethics policy. Develop, maintain, and consistently follow an AI ethics procedure by creating a use-case-by-use-case process. Policies based on universal checklists often silence awareness when it is most needed.

Cybersecurity leaders must work closely with their DPO and legal counsel to determine the exact requirements for compliance and monitoring in AI systems and use cases.

Securing Feedback Loops

Feedback loops ensure GenAI systems improve over time. They include the curation and processing of feedback used to enhance output, optimize raw data, or eventually retrain a model.

Eventually, user interaction can increase model accuracy, ethical alignment, and enhance model security. Feedback is diverse and may differ, for example, in source (humans, sensors, AI agents), volume, data type, and whether it is an explicit report, such as humans flagging harmful content or machines detecting toxicity scores. Thus, security concerns differ based on the feedback type. The human in the loop provides nuanced insights to help address complex security and ethical challenges that automated systems might overlook or misinterpret.

There are also security-relevant dependencies on whether a GenAI architecture embeds live feedback as signals for dynamic feature engineering (for example, new features being automatically and transparently prepended to input vectors), context engineering, or ensemble methods (e.g., the guardrail model).

Key security challenges cybersecurity leaders should consider and recommended countermeasures include:

- **Feedback poisoning:** Where malicious actors submit fake feedback or reports to poison model training or overwhelm feedback triage systems and processes.
  - *Recommended countermeasures:*

    - Feedback sandbox testing where feedback is applied to the AI architecture in a canary mode and monitored for anomalies.
    - Anomaly detection to uncover, for example, unusual feedback volume.
- **Sensor or agent spoofing:** Where attackers spoof sensors or agents to manipulate input data to suppress legitimate alerts or trigger false alarms.
    - *Recommended countermeasures*
        - Feedback provenance verification (does the feedback originate from trusted sources) and attestation, such as signing.

⊕ Evidence

Unlock more AI value

With unmatched, proprietary AI insights from Gartner

Explore the AI Hub ↗

© 2026 Gartner, Inc. and/or its affiliates. All rights reserved. Gartner is a registered trademark of Gartner, Inc. and its affiliates. This publication may not be reproduced or distributed in any form without Gartner's prior written permission. It consists of the opinions of Gartner's research organization, which should not be construed as statements of fact. While the information contained in this publication has been obtained from sources believed to be reliable, Gartner disclaims all warranties as to the accuracy, completeness or adequacy of such information. Although Gartner research may address legal and financial issues, Gartner does not provide legal or investment advice and its research should not be construed or used as such. Your access and use of this publication are governed by Gartner's Usage Policy. Gartner prides itself on its reputation for independence and objectivity. Its research is produced independently by its research organization without input or influence from any third party. For further information, see "Guiding Principles on Independence and Objectivity." Gartner research may not be used as input into or for the training or development of generative artificial intelligence, machine learning, algorithms, software, or related technologies.

© 2026 Gartner, Inc. and/or its Affiliates. All Rights Reserved.

© 2026 Gartner, Inc. and/or its affiliates. All rights reserved.